Policy Reference — Actual Policies and Simple Explanations

Each policy is shown first in a readable JSON block, followed by a plain-English explanation. AWS-managed policies are referenced by name rather than reproducing AWS-maintained JSON, which can change over time.

A. Policies attached to the EC2 IAM roles

1. AmazonSSMManagedInstanceCore — attached to both roles

AWS-managed policy. It provides the core permissions required for EC2 instances to register with and communicate with Systems Manager. Its full JSON is maintained by AWS and is intentionally not copied here; the policy name links the exact managed policy in IAM.

2. AWS-quick-setup-RunPatchBaseline — attached to both roles

Actual customer-managed policy JSON:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ReadQuickSetupPatchBaseline",
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::aws-quicksetup-patchpolicy-754025990014-yld5i/*"
    }
  ]
}
```

Simple explanation: This lets the instance read Patch Manager's Quick Setup configuration files from that specific bucket. It does not grant access to every S3 bucket.

3. CloudShield-PatchLog-S3-Access — attached to both roles

Actual customer-managed policy JSON:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "WritePatchManagerLogs",
      "Effect": "Allow",
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::cloudshield-patch-manager-logs/*"
    }
  ]
}
```

Simple explanation: This allows the instances to upload Patch Manager output files to the objects inside cloudshield-patch-manager-logs. It does not allow them to read or delete those objects.

4. CloudShield-Backend-RolePolicy — inline policy on the backend role

Actual customer-managed inline policy JSON:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "CloudShieldS3Access",
      "Effect": "Allow",
      "Action": [
        "s3:GetBucketLocation",
        "s3:ListBucket",
        "s3:GetObject",
        "s3:PutObject",
        "s3:DeleteObject"
      ],
      "Resource": [
        "arn:aws:s3:::cloudshield-s3-bucket",
        "arn:aws:s3:::cloudshield-s3-bucket/*"
      ]
    }
  ]
}
```

Simple explanation: The backend role can check the bucket's Region, list its objects, read objects, upload objects, and delete objects in cloudshield-s3-bucket. The permissions are limited to this project bucket and its contents.

Quick Setup tag (not an IAM policy): QSConfigId-yld5i = yld5i. The tag identifies the Quick Setup configuration; it does not itself grant access.

B. S3 Gateway VPC Endpoint policy

Actual policy JSON recorded for the endpoint:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowCloudShieldBucketAccess",
      "Effect": "Allow",
      "Principal": "*",
      "Action": [
        "s3:GetBucketLocation",
        "s3:ListBucket",
        "s3:GetObject",
        "s3:PutObject",
        "s3:DeleteObject"
      ],
      "Resource": [
        "arn:aws:s3:::cloudshield-s3-bucket",
        "arn:aws:s3:::cloudshield-s3-bucket/*"
      ]
    },
    {
      "Sid": "AllowPatchManagerLogsBucketAccess",
      "Effect": "Allow",
      "Principal": "*",
      "Action": [
        "s3:GetBucketLocation",
        "s3:ListBucket",
        "s3:GetObject",
        "s3:PutObject"
      ],
      "Resource": [
        "arn:aws:s3:::cloudshield-patch-manager-logs",
        "arn:aws:s3:::cloudshield-patch-manager-logs/*"
      ]
    },
    {
      "Sid": "AllowAmazonLinux2023Repository",
      "Effect": "Allow",
      "Principal": "*",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::al2023-repos-ap-south-1-de612dc2/*"
    },
    {
      "Sid": "AllowSSMPatchPayloads",
      "Effect": "Allow",
      "Principal": "*",
      "Action": "s3:GetObject",
      "Resource": [
        "arn:aws:s3:::aws-ssm-ap-south-1/*",
        "arn:aws:s3:::patch-baseline-snapshot-ap-south-1/*",
        "arn:aws:s3:::aws-patch-manager-ap-south-1-cb7c62ff9/*",
        "arn:aws:s3:::aws-quicksetup-patchpolicy-754025990014-yld5i/*"
      ]
    }
  ]
}
```

Statement-by-statement explanation

Statement	What it allows / why it exists
AllowCloudShieldBucketAccess	Allows the listed bucket-level actions and object read/write/delete actions for cloudshield-s3-bucket through this endpoint.
AllowPatchManagerLogsBucketAccess	Allows bucket lookup/listing and object read/write actions for cloudshield-patch-manager-logs, including uploading Patch Manager output.
AllowAmazonLinux2023Repository	Allows downloading Amazon Linux 2023 repository objects from the specified regional repository bucket.
AllowSSMPatchPayloads	Allows downloading objects from the listed SSM, patch baseline snapshot, patch manager, and Quick Setup buckets. This was added to allow the required patch files/configuration to be retrieved.

Important: This endpoint policy is a filter for requests travelling through the endpoint. It does not replace the EC2 role policy or the S3 bucket policy. The request must be allowed by all applicable authorization controls.

C. Bucket policy for cloudshield-s3-bucket

Actual bucket policy JSON recorded for the project storage bucket:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyInsecureTransport",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:*",
      "Resource": [
        "arn:aws:s3:::cloudshield-s3-bucket",
        "arn:aws:s3:::cloudshield-s3-bucket/*"
      ],
      "Condition": {
        "Bool": {
          "aws:SecureTransport": "false"
        }
      }
    }
  ]
}
```

Simple explanation

• **Effect: Deny** — blocks requests that match the condition, even if another policy allows them.
• **Principal: *** — the rule applies to any requester, subject to the condition and resource scope.
• **Action: s3:*** — covers S3 actions on the specified bucket and objects.
• **Condition aws:SecureTransport = false** — matches requests that do not use secure transport (HTTP). HTTPS requests do not match this deny condition.

Why it matters

This policy enforces secure transport for access to cloudshield-s3-bucket. It protects data in transit, but it does not encrypt stored objects by itself and does not grant access. IAM permissions, Block Public Access, and the endpoint policy (when the endpoint is used) remain separate controls.

Scope note

This section intentionally covers only cloudshield-s3-bucket, the project bucket policy created by you. Policies on the CloudTrail/Flow Logs and Patch Manager buckets are not explained here because the project record indicates they were created by AWS services or AWS configuration workflows.

Final outcome

CloudShield brings together network segmentation, multi-AZ web entry, a private backend and database tier, IAM-based instance access, controlled S3 access, monitoring and notifications, audit logging, and Systems Manager operations. The supplied evidence also records two practical resolutions: migrating the backend EBS volume to an encrypted replacement and resolving Patch Manager's S3 access/output delivery requirements.

This document distinguishes the intended architecture from confirmed test results. Patch Manager's final association was a Scan operation, and no application endpoint is claimed as operational unless supported by a separate test.